

CTF "THE 27 CLUB"

UNIVERSIDAD DE CUNDINAMARCA
Programa: Ingeniería de Sistemas y Computación
Autor: Oscar Giovanni Robayo Olaya
Documento: Propuesta Inicial de Proyecto - Etical Hacking

---

1. Planteamiento del Proyecto

El presente documento plantea el diseño de un entorno de entrenamiento en Hacking Ético estructurado bajo la modalidad *Capture The Flag* (CTF). El escenario, denominado **"The 27 Club"**, tiene como objetivo evaluar las habilidades de *Red Teaming* de manera progresiva a través de cinco fases narrativas basadas en artistas musicales icónicos.

Este proyecto propone una arquitectura gamificada que centraliza el avance en un **Tablero de Control interactivo**, permitiendo que el ejercicio fluya de manera inmersiva en un tiempo máximo de **2 horas (120 minutos)**.

2. Arquitectura de Gamificación y Mecánicas

- **Tablero de Control Interactivo:** Interfaz web centralizada que escucha eventos de captura. Al registrar una bandera, actualiza el porcentaje de completitud en tiempo real.
- **Retroalimentación Auditiva y Visual:** Por cada bandera capturada, el sistema emite un fragmento de audio del artista correspondiente, validando el éxito del ataque.
- **Sistema de Pistas (Hints) Penalizadas:** Módulo de asistencia técnica que reduce el puntaje final al ser utilizado, incentivando el análisis forense exhaustivo.
- **Falsos Positivos (Rabbit Holes/Honeypots):** Implementación de rutas y puertos señuelo que despliegan interacciones distractoras para consumir el tiempo del atacante.

3. Fases de Explotación y Banderas Temáticas

El entorno requiere que el atacante escale desde la enumeración inicial hasta el compromiso total del servidor.

Fase 1: Jimi Hendrix (Reconocimiento y Criptografía Clásica)

- **Vector de Ataque:** Escaneo de red (Nmap) y análisis forense de paquetes (Wireshark).
- **Reto Específico:** Descifrar una cadena ofuscada en Código César interceptada en tráfico residual.
- **Bandera Esperada:** `FLAG{Purple_Haze_Network}`

Fase 2: Janis Joplin (Enumeración Web y Esteganografía)

- **Vector de Ataque:** Fuzzing de directorios e inspección de metadatos.
- **Reto Específico:** Extraer información oculta dentro de una imagen usando herramientas de esteganografía.
- **Bandera Esperada:** `FLAG{Cry_Baby_Hidden_Data}`

Fase 3: Jim Morrison (Inyección SQL y Evasión de Honeypots)

- **Vector de Ataque:** SQL Injection (SQLi) y Bypass de Autenticación.
- **Reto Específico:** Evadir un *Honeypot* web analizando cabeceras HTTP y ejecutar el payload SQL en el login real.
- **Bandera Esperada:** `FLAG{Riders_On_The_Storm_DB}`

Fase 4: Amy Winehouse (Cross-Site Scripting - XSS)

- **Vector de Ataque:** Explotación de vulnerabilidades del lado del cliente.
- **Reto Específico:** Inyectar un payload JavaScript evadiendo sanitizaciones para robar una cookie de sesión.
- **Bandera Esperada:** `FLAG{Back_To_Black_Session}`

Fase 5: Kurt Cobain (Escalación de Privilegios a Root)

- **Vector de Ataque:** Escalación de privilegios locales y fuerza bruta de sistema.
- **Reto Específico:** Enumerar binarios SUID o archivos expuestos desde una shell de bajos privilegios para migrar a `root`.
- **Bandera Esperada:** `FLAG{Nirvana_Root_Access_Granted}` (Ubicada en /root/flag.txt).

4. Entorno de Laboratorio y Requisitos

- **Máquina Atacante:** Distribución Kali Linux (Máquina Virtual).
- **Host Físico:** Windows 11.
- **Servidor Objetivo:** Despliegue de aplicación Dockerizada.